Joint Risk Assessment and Pricing in Cyber Insurance QUBO-QAOA Approach

Alice Busi, Clara Hamousz, Giovanni Bragadin, Timothé Jobin

EPFL

March 1, 2026

Overview

1. Target function
   - Acceptance function
   - Cost of controls
   - Ransomware risk assessment
   - Discretizing premiums
2. From QUBO to QAOA
3. Results
4. Conclusion

Overview

1. Target function
   - Acceptance function
   - Cost of controls
   - Ransomware risk assessment
   - Discretizing premiums
2. From QUBO to QAOA
3. Results
4. Conclusion

Overview

1. Target function
   - Acceptance function
   - Cost of controls
   - Ransomware risk assessment
   - Discretizing premiums
2. From QUBO to QAOA
3. Results
4. Conclusion

Overview

1. Target function
   - Acceptance function
   - Cost of controls
   - Ransomware risk assessment
   - Discretizing premiums
2. From QUBO to QAOA
3. Results
4. Conclusion

Why Cyber Insurance is Different

Stronger controls

- $\downarrow$ Expected loss
- $\uparrow$ Client friction

Higher premium

- $\uparrow$ Margin
- $\downarrow$ Acceptance probability

All decisions interact.

Cyber underwriting is a joint risk assessment and pricing optimization problem.

Why Cyber Insurance is Different

Stronger controls

- $\downarrow$ Expected loss
- $\uparrow$ Client friction

Higher premium

- $\uparrow$ Margin
- $\downarrow$ Acceptance probability

All decisions interact.

Cyber underwriting is a joint risk assessment and pricing optimization problem.

Why Cyber Insurance is Different

Stronger controls

- $\downarrow$ Expected loss
- $\uparrow$ Client friction

Higher premium

- $\uparrow$ Margin
- $\downarrow$ Acceptance probability

All decisions interact.

Cyber underwriting is a joint risk assessment and pricing optimization problem.

Why Cyber Insurance is Different

Stronger controls

- $\downarrow$ Expected loss
- $\uparrow$ Client friction

Higher premium

- $\uparrow$ Margin
- $\downarrow$ Acceptance probability

All decisions interact.

Cyber underwriting is a joint risk assessment and pricing optimization problem.

Target function

The primary optimization goal is to minimize the Joint Loss Function $\mathcal{J}(\theta, Z)$, effectively maximizing the insurer's expected profit.

Joint Loss Function

$$\mathcal{J}(\theta, Z) = -\mathbb{E}[\text{Profit}(\theta, Z)]$$

Expected Profit

$$\mathbb{E}[\text{Profit}(\theta, Z)] = A(\theta, Z)\Big[p - C_{ctrl}(x) - \mathbb{E}[\text{Payout}(\theta, Z)]\Big]$$

- $A(\theta, Z)$: Customer acceptance probability, modeled as a logistic function of premium difference, underwriting friction, and policy terms.
- p: Annual premium decision variable.
- $C_{ctrl}(x)$: Underwriting cost of requiring controls, calculated as $\sum_{i \in V} \kappa_i x_i$.
- $\mathbb{E}[\text{Payout}(\theta, Z)]$: Expected insurer payout based on ransomware frequency, severity, deductible, and limit

Acceptance function

To preserve the quadratic structure of the final objective, the nonlinear probability of a client accepting the insurance offer is approximated using a first-order Taylor expansion around a baseline operating point (L_0).

First-Order Approximation

$$A(x, p) = \alpha_0 + \alpha_p p + \sum_{i \in V} \alpha_i x_i$$

- **Baseline Acceptance (α_0):** Incorporates the competitor benchmark, policy limit, and deductible.

$$\alpha_0 = A_0 + A_0(1 - A_0)(\tilde{\eta}_0 - L_0)$$

- **Premium Sensitivity (α_p):** Captures the reduction in demand as the offered premium (p) increases.

$$\alpha_p = -A_0(1 - A_0)\eta_p$$

- **Friction Penalty (α_i):** Reflects the drop in acceptance due to the client effort (f_i) required to implement control x_i.

$$\alpha_i = -A_0(1 - A_0)\eta_c f_i$$

Cost of controls

Linear Control Cost Function

$$C_{ctrl}(x) = \sum_{i \in V} \kappa_i x_i$$

- $x_i \in \{0, 1\}$**:** The binary decision variable indicating whether control i is required ($x_i = 1$) or not ($x_i = 0$).
- κ_i**:** The specific `control_cost` associated with control i.
- **Interpretation:** κ_i represents the insurer's verification cost, underwriting friction, or normalized effort units required to assess that specific control.

Integration into Objective: Because it is strictly a first-order sum, $C_{ctrl}(x)$ integrates directly into the linear coefficients (C_i) of the final quadratic expected profit function without introducing higher-order cross-terms.

Ransomware risk assessment

- **Expected Payout:** Product of the probability of a ransom occurring and the impact of it

$$\mathbb{E}[\text{Payout}(\theta, Z)] = Pr_{ran}(x, Z) \times Impact(x, Z)$$

- **Frequency:** Modeled via effective intensity λ_{eff} and security score $S(x)$.

$$Pr_{ran}(x, Z) = 1 - \exp\Big(-\lambda_{eff}(x, Z) \cdot \hat{A} \cdot \hat{E} \cdot [1 - S(x)]\Big)$$

- **Severity:** Combines recovery costs, downtime business interruption, and reputational damage.

$$Impact(x, Z) = Impact_0(x, Z) \cdot \Phi_{sev}(x)$$

- **Proxies:** IT assets ($\hat{A}$) and exposure index ($\hat{E}$) are derived from firm size (N), cloud dependency (C), and remote work (R).

Ransom probability and impact

To finalize the formulation for quantum readiness, both the probability and the adjusted impact are expressed as quadratic forms of the binary control variables x_i.

- **Probability Formulation:**

$$Pr_{ran}(x) = P_0 + \sum_i P_i x_i + \sum_{i<j} P_{ij} x_i x_j$$

- **Adjusted Impact ($\tilde{I}_0 = I_0 - d$):**

$$Impact(x) - d = \tilde{I}_0 + \sum_i I_i x_i + \sum_{i<j} I_{ij} x_i x_j$$

Final Truncation

Multiplying these two quadratic polynomials generates higher-order terms. By expanding and truncating terms above the second order, we obtain the final QUBO-ready expression:

$$\mathbb{E}[Payout](x) = E_0 + \sum_i E_i x_i + \sum_{i<j} E_{ij} x_i x_j$$

Discretizing premiums

To solve the problem using techniques like QAOA or Quantum Annealing, the nonlinear model is reduced to a **QUBO** (Quadratic Unconstrained Binary Optimization) form:

- **Binary Controls:** $x_i \in \{0, 1\}$ for n cybersecurity protocols.
- **Premium Discretization:** p is expanded into M binary bits b_m.

$$p = p_{min} + \Delta \sum_{m=0}^{M-1} 2^m b_m$$

- **Complexity:** The search space is $|\Omega| = 2^{n+M}$, making the problem NP-hard.

Final Optimization Problem

After linearization and premium discretization, the cyber underwriting problem reduces to:

$$\min_{z \in \{0,1\}^N} \; z^\top Q z + c$$

Decision vector:

$$z = (x_1, \ldots, x_n, b_0, \ldots, b_{M-1})$$

- x_i = required cybersecurity controls
- b_m = binary encoding of the premium

Equivalent to minimizing the Joint Loss:

$$J(\theta, Z) = -\mathbb{E}[\text{Profit}(\theta, Z)]$$

Model Output:

- Optimal set of controls to require
- Optimal premium to charge

The optimal bitstring identifies the underwriting decision that maximizes AXA's expected profit under the modeled assumptions.

Step 1: QUBO Formulation

We start from a Quadratic Unconstrained Binary Optimization (QUBO) problem.

$$\min_{x \in \{0,1\}^n} \quad x^T Q x + c^T x$$

where:

- $x_i \in \{0, 1\}$ are binary decision variables
- Q is a symmetric matrix (quadratic terms)
- c contains linear coefficients

This form is directly compatible with many combinatorial optimization problems.

Step 1: QUBO Formulation

We start from a Quadratic Unconstrained Binary Optimization (QUBO) problem.

$$\min_{x \in \{0,1\}^n} \quad x^T Q x + c^T x$$

where:

- $x_i \in \{0, 1\}$ are binary decision variables
- Q is a symmetric matrix (quadratic terms)
- c contains linear coefficients

This form is directly compatible with many combinatorial optimization problems.

Step 2: QUBO to Ising Mapping

Quantum hardware works in the Ising basis.

We transform binary variables:

$$x_i \in \{0, 1\} \quad \longrightarrow \quad s_i \in \{-1, +1\}$$

$$x_i = \frac{1 - s_i}{2}$$

Substituting into the QUBO objective gives:

$$H(s) = \sum_i h_i s_i + \sum_{i<j} J_{ij} s_i s_j + \text{constant}$$

This is the Ising Hamiltonian.

Step 2: QUBO to Ising Mapping

Quantum hardware works in the Ising basis.

We transform binary variables:

$$x_i \in \{0, 1\} \quad \longrightarrow \quad s_i \in \{-1, +1\}$$

$$x_i = \frac{1 - s_i}{2}$$

Substituting into the QUBO objective gives:

$$H(s) = \sum_i h_i s_i + \sum_{i<j} J_{ij} s_i s_j + \text{constant}$$

This is the Ising Hamiltonian.

Ising Hamiltonian Form

The optimization problem becomes energy minimization:

$$H = \sum_i h_i Z_i + \sum_{i<j} J_{ij} Z_i Z_j$$

where:

- Z_i are Pauli-Z operators
- h_i are local fields
- J_{ij} are coupling strengths

The ground state corresponds to the optimal solution.

Ising Hamiltonian Form

The optimization problem becomes energy minimization:

$$H = \sum_i h_i Z_i + \sum_{i<j} J_{ij} Z_i Z_j$$

where:

- Z_i are Pauli-Z operators
- h_i are local fields
- J_{ij} are coupling strengths

The ground state corresponds to the optimal solution.

Step 3: Applying QAOA

QAOA approximates the ground state of the Ising Hamiltonian.

The variational state is:

$$|\psi(\boldsymbol{\gamma}, \boldsymbol{\beta})\rangle = \prod_{k=1}^{p} e^{-i\beta_k H_M} e^{-i\gamma_k H_C} |+\rangle^{\otimes n}$$

where:

- H_C = Ising cost Hamiltonian
- $H_M = \sum_i X_i$ (mixer Hamiltonian)
- p = circuit depth

Step 3: Applying QAOA

QAOA approximates the ground state of the Ising Hamiltonian.

The variational state is:

$$|\psi(\boldsymbol{\gamma}, \boldsymbol{\beta})\rangle = \prod_{k=1}^{p} e^{-i\beta_k H_M} e^{-i\gamma_k H_C} |+\rangle^{\otimes n}$$

where:

- $H_C =$ Ising cost Hamiltonian
- $H_M = \sum_i X_i$ (mixer Hamiltonian)
- $p =$ circuit depth

QAOA Optimization Procedure

Hybrid Quantum-Classical Loop

1. Encode QUBO into Ising Hamiltonian
2. Build QAOA circuit
3. Measure expectation value $\langle H_C \rangle$
4. Classical optimizer updates (γ, β)

The final measured bitstring approximates the optimal QUBO solution.

QAOA Optimization Procedure

Hybrid Quantum-Classical Loop

1. Encode QUBO into Ising Hamiltonian
2. Build QAOA circuit
3. Measure expectation value $\langle H_C \rangle$
4. Classical optimizer updates (γ, β)

The final measured bitstring approximates the optimal QUBO solution.

Results: Experimental Setting

Tested Configuration

Medium-sized technology company

- 3 binary security controls x_1, x_2, x_3
- 3-bit premium encoding p_1, p_2, p_3
- Total decision space: $2^6 = 64$

Complete QUBO $\rightarrow$ Ising $\rightarrow$ QAOA pipeline executed successfully.

Results: Optimization Outcome

QAOA Output

- Convergent optimal bitstring
- Premium decoded classically
- Expected profit reconstructed

$$\mathbb{E}[\text{Profit}](x^*, p^*) < 0$$

Results: Economic Interpretation

Underwriting Implication

Under the modeled assumptions:

- No feasible configuration yields positive margin
- Risk–return trade-off is unfavorable

Rational decision: decline coverage.

Results: Interpretation and Limits

Discussion

The negative profit reflects:

- Interaction between premium, expected loss, and control costs
- Discretization limits in premium encoding
- Quadratic approximation of the profit function

Model simplifications:

- Implicit moderate-risk assumption
- Limited representation of extreme loss events
- Execution restricted to 6 qubits

Results: Scalability Implications

Dimensional Growth

With n controls and b premium bits:

$$\text{Search space} = 2^{n+b}$$

More controls $\rightarrow$ richer risk modeling More bits $\rightarrow$ finer pricing resolution

Both increase combinatorial complexity.

Conclusion

- The framework unifies risk mitigation, pricing, and demand modeling into a single optimization task.
- Linearization transforms the complex underwriting problem into a structured QUBO matrix.
- This approach enables data-driven, resilient insurance strategies suitable for advanced computational solvers.

Backup — Computational Complexity

Final formulation: QUBO problem

$$\max_{z \in \{0,1\}^N} z^\top Q z + c$$

where:

$$z = (x_1, \ldots, x_n, b_0, \ldots, b_{M-1}), \quad N = n + M$$

Search space size:

$$|\Omega| = 2^N$$

Number of quadratic terms:

$$\mathcal{O}(n^2 + nM + M^2) = \mathcal{O}(N^2)$$

Complexity class:

- Binary quadratic optimization
- NP-hard
- Worst-case time: $\mathcal{O}(2^N)$

Main driver of complexity: number of security controls n

Backup — Full Economic Objective

The insurer maximizes expected profit:

$$\mathbb{E}[\text{Profit}(\theta, Z)] = A(\theta, Z)\,[p - C_{\text{ctrl}}(x) - \mathbb{E}[\text{Payout}(\theta, Z)]]$$

Components included:

- Acceptance probability $A(\theta, Z)$
- Premium p
- Control cost $C_{\text{ctrl}}(x)$
- Expected ransomware payout

Joint Loss:

$$J(\theta, Z) = -\mathbb{E}[\text{Profit}(\theta, Z)]$$

Backup — Acceptance Model

Customer acceptance probability:

$$A(\theta, Z) = \frac{1}{1 + \exp\left(-[\eta_0 - \eta_p(p - p_{\text{comp}}) - \eta_c F(x)]\right)}$$

Includes:

- Premium difference vs competitor
- Underwriting friction $F(x)$
- Policy terms (deductible, limit)

Captures demand elasticity and competitive pressure.

Backup — Ransomware Risk Model

Expected payout:

$$\mathbb{E}[\text{Payout}(\theta, Z)] = \Pr_{\text{ran}}(x, Z) \cdot \text{Pay}(\text{Impact}(x, Z))$$

Probability of ransomware:

$$\Pr_{\text{ran}}(x, Z) = 1 - \exp\left(-\lambda_{\text{eff}}(x, Z)\hat{A}\hat{E}[1 - S(x)]\right)$$

Severity model:

$$\text{Impact}(x, Z) = \text{Impact}_0(x, Z) \cdot \Phi_{\text{sev}}(x)$$

Backup — Security Controls and Posture

Latent security score:

$$z(x) = z_0 + \sum_i w_i x_i + \sum_{i<j} w_{ij} x_i x_j$$

$$S(x) = \sigma(z(x))$$

Controls affect:

- Frequency reduction (α_i)
- Severity reduction (β_i)
- Customer friction (f_i)

Controls interact through quadratic terms.

Backup — Impact Model (Severity)

Baseline economic impact:

$$\text{Impact}_0(x, Z) = c_1 \hat{A} + \frac{\text{Rev}}{365} \left[d_0 + d_1 \hat{A}(1 - S(x)) \right] + \gamma \, \text{Rev}$$

Components included:

- Recovery cost per asset ($c_1 \hat{A}$)
- Downtime business interruption
- Legal and reputational cost (γRev)

Controls reduce severity multiplicatively:

$$\text{Impact}(x, Z) = \text{Impact}_0(x, Z) \cdot \Phi_{\text{sev}}(x)$$